

SOC/L1 - 4.6. Eviction

Scenario:

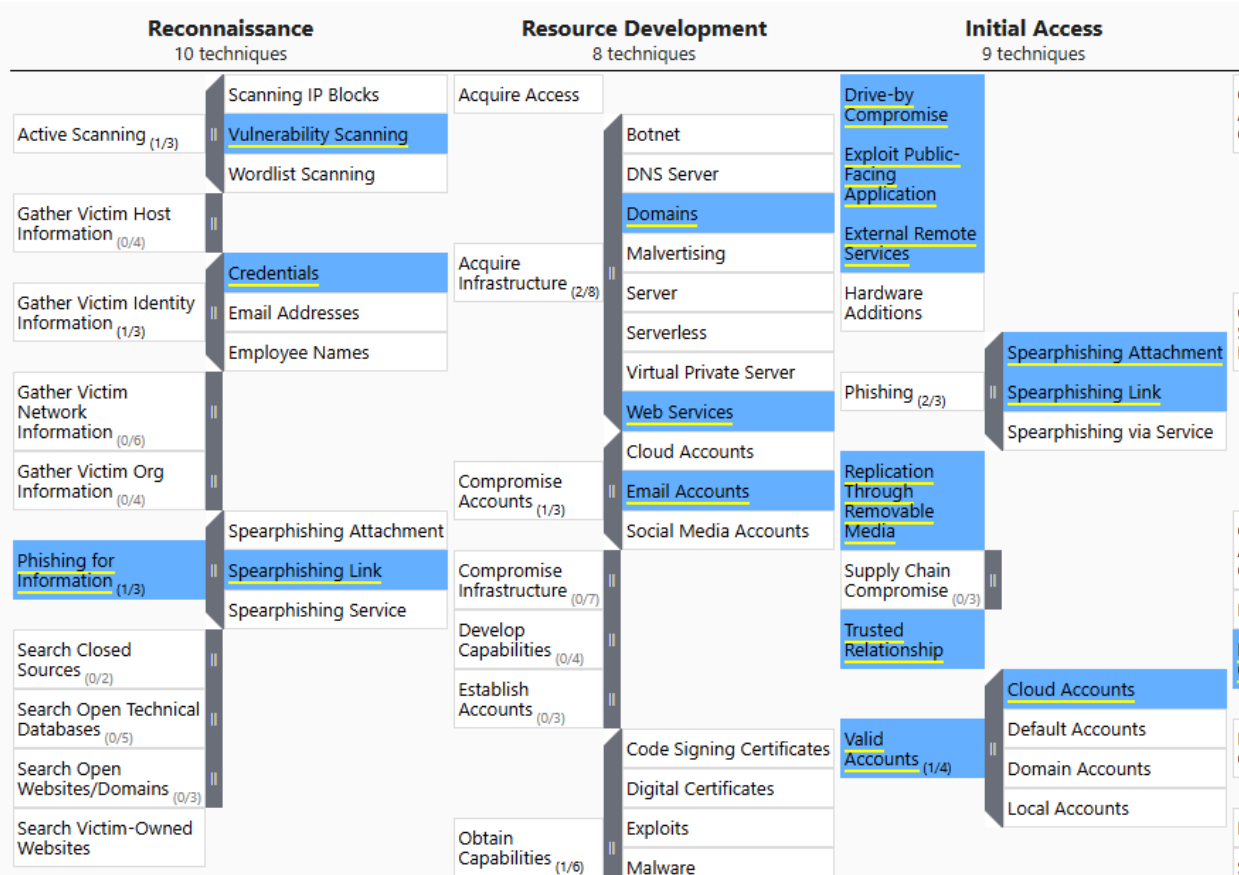
Sunny is a SOC analyst at E-corp, which manufactures rare earth metals for government and non-government clients. She receives a classified intelligence report that informs her that an APT group (APT28) might be trying to attack organizations similar to E-corp. To act on this intelligence, she must use the MITRE ATT&CK Navigator to identify the TTPs used by the APT group, to ensure it has not already intruded into the network, and to stop it if it has.

Answer the questions below

What is a technique used by the APT to both perform recon and gain initial access?

Spearphishing link

When we check reconnaissance and initial access phase , we will see the mutual technic is spearphishing



Sunny identified that the APT might have moved forward from the recon phase. Which accounts might the APT compromise while developing resources?

Email accounts

(next step is resource development after reconnaissance phase, easily compromise email accounts after spearphishing)

Resource Development 8 techniques	
Acquire Access	
	Botnet
	DNS Server
	<u>Domains</u>
Acquire Infrastructure (2/8)	Malvertising
	Server
	Serverless
	Virtual Private Server
	<u>Web Services</u>
Compromise Accounts (1/3)	Cloud Accounts
	<u>Email Accounts</u>
	Social Media Accounts
Compromise Infrastructure (0/7)	
Develop Capabilities (0/4)	
Establish Accounts (0/3)	
	Code Signing Certificates
	Digital Certificates
Obtain Capabilities (1/6)	Exploits
	Malware
	<u>Tool</u>
	Vulnerabilities
Stage Capabilities (0/6)	

E-corp has found that the APT might have gained initial access using social engineering to make the user execute code for the threat actor. Sunny wants to identify if the APT was also successful in execution. What two techniques of user execution should Sunny look out for?

Malicious file and malicious link (Check the 14 techniques in the Execution section; the relevant sections are available under User Executions.)

Execution 14 techniques	
Cloud Administration Command	
	AppleScript
	Cloud API
	JavaScript
	Network Device CLI
Command and Scripting Interpreter (2/9)	PowerShell
	Python
	Unix Shell
	Visual Basic
	Windows Command Shell
Container Administration Command	
Deploy Container	
Exploitation for Client Execution	
	Component Object Model
Inter-Process Communication (1/3)	Dynamic Data Exchange
	XPC Services
Native API	
Scheduled Task/Job (0/5)	
Serverless Execution	
Shared Modules	
Software Deployment Tools	
System Services (0/2)	
	Malicious File
User Execution (2/3)	Malicious Image
	Malicious Link

If the above technique was successful, which scripting interpreters should Sunny search for to identify successful execution?

Powershell and Windows Command shell (Check the previous picture for the Command and Scripting Interpreter section.)

While looking at the scripting interpreters identified in Q4, Sunny found some obfuscated scripts that changed the registry. Assuming these changes are for maintaining persistence, which registry keys should Sunny observe to track these changes?

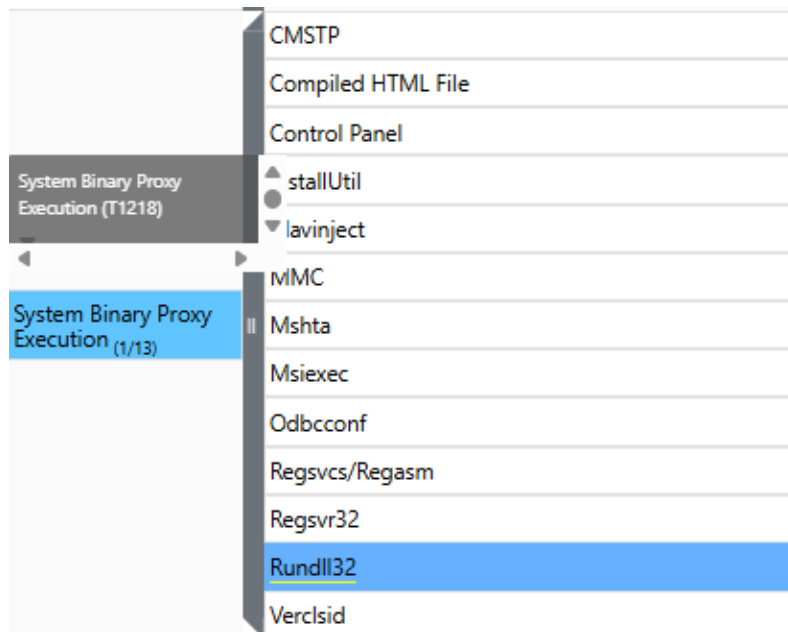
Registry run keys

Persistence 19 techniques	
Account Manipulation (1/5)	Additional Cloud Credentials
	Additional Cloud Roles
	Additional Email Delegate Permissions
	Device Registration
	SSH Authorized Keys
BITS Jobs	
Boot or Logon Autostart Execution (1/14)	Active Setup
	Authentication Package
	Kernel Modules and Extensions
	Login Items
	LSASS Driver
	Port Monitors
	Print Processors
	Re-opened Applications
	Registry Run Keys / Startup Folder
	Security Support Provider
	Shortcut Modification
	Time Providers
	Winlogon Helper DLL
	XDG Autostart Entries
Boot or Logon Initialization Scripts (1/5)	Login Hook
	Logon Script (Windows)
	Network Logon Script
	RC Scripts
Browser Extensions	Startup Items
Compromise Client Software Binary	
Create	

Sunny identified that the APT executes system binaries to evade defences.
Which system binary's execution should Sunny scrutinize for proxy execution?

Rundll32

Defense Evasion	
42 techniques	
Abuse Elevation Control Mechanism (0/4)	II
	Create Process with Token
	Make and Impersonate Token
Access Token Manipulation (1/5)	II
	Parent PID Spoofing
	SID-History Injection
	Token Impersonation/Theft
BITS Jobs	
Build Image on Host	
Debugger Evasion	
Deobfuscate/Decode Files or Information	
Deploy Container	
Direct Volume Access	
Domain Policy Modification (0/2)	II
Execution Guardrails (0/1)	II
Exploitation for Defense Evasion	
File and Directory Permissions Modification (0/2)	II



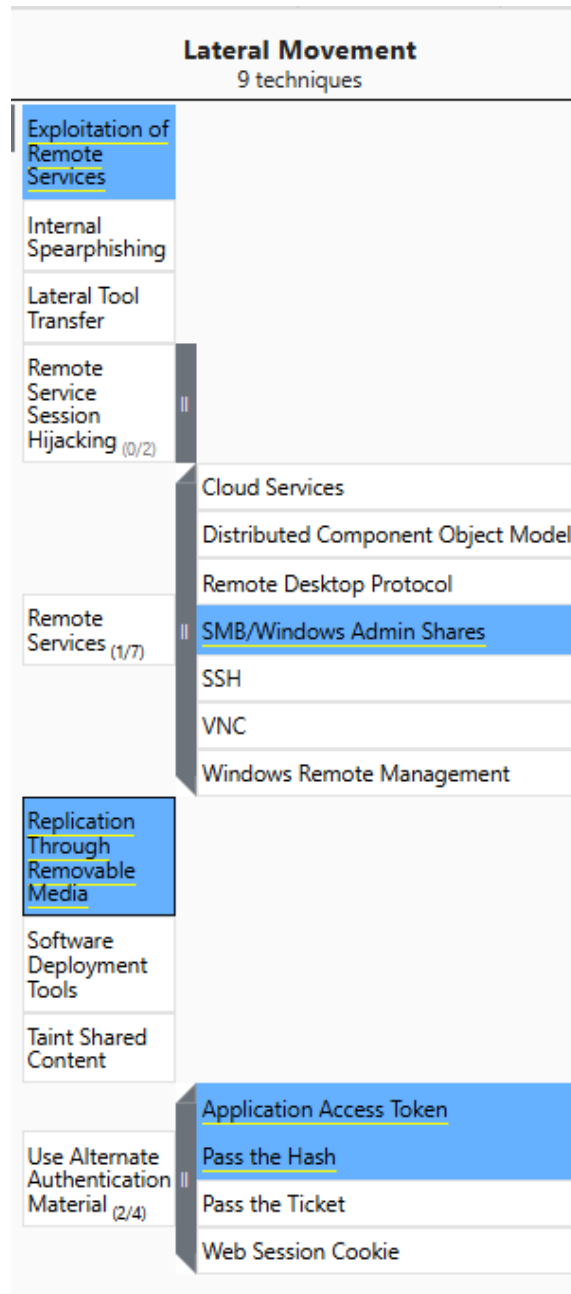
Sunny identified tcpdump on one of the compromised hosts. Assuming this was placed there by the threat actor, which technique might the APT be using here for discovery?

Network sniffing (For tpc dump uses network sniipping)

Credential Access	
17 techniques	
Adversary-in-the-Middle (0/3)	II
	Credential Stuffing
Brute Force (2/4)	II
	Password Cracking
	Password Guessing
	Password Spraying
Credentials from Password Stores (0/5)	II
Exploitation for Credential Access	
Forced Authentication	
Forge Web Credentials (0/2)	II
	Credential API Hooking
Input Capture (1/4)	II
	GUI Input Capture
	Keylogging
	Web Portal Capture
Modify Authentication Process (0/8)	II
Multi-Factor Authentication Interception	
Multi-Factor Authentication Request Generation	
Network Sniffing	

It looks like the APT achieved lateral movement by exploiting remote services. Which remote services should Sunny observe to identify APT activity traces?

SMB/Windows Admin shares



It looked like the primary goal of the APT was to steal intellectual property from E-corp's information repositories. Which information repository can be the likely target of the APT?

Sharepoint

Collection	
17 techniques	
Adversary-in-the-Middle (0/3)	II
Archive Collected Data (1/3)	Archive via Custom Method II Archive via Library Archive via Utility
Audio Capture	
Automated Collection	
Browser Session Hijacking	
Clipboard Data	
Data from Cloud Storage	
Data from Configuration Repository (0/2)	II
Data from Information Repositories (1/3)	Code Repositories II Confluence Sharepoint
Data from Local System	
Data from Network Shared Drive	
Data from Removable Media	
Data Staged (2/2)	Local Data Staging Remote Data Staging
Email Collection (1/3)	Email Forwarding Rule II Local Email Collection Remote Email Collection

Although the APT had collected the data, it could not connect to the C2 for data exfiltration. To thwart any attempts to do that, what types of proxy might the APT use?

external proxy and multi-hop proxy

Exfiltration	
9 techniques	
Automated Exfiltration (0/1)	
Data Transfer Size Limits	
Exfiltration Over Alternative Protocol (1/3)	Exfiltration Over Asymmetric Encrypted Non-C2 Protocol Exfiltration Over Symmetric Encrypted Non-C2 Protocol Exfiltration Over Unencrypted Non-C2 Protocol
Exfiltration Over C2 Channel	